

- System and service inventories to determine how well the inventories identify all systems and services, how well they categorize each system and service's criticality, and how well they identify the entire supply chain needed to provide the system or service.
- Entity's methods for initially assessing and monitoring after implementation for provenance of systems, components, and data.
- Communication processes and documented communication of threat intelligence and vulnerability identification with supply chain partners.
- Entity management's assessment of supply chain partners' programs to address inauthentic or unapproved systems or components (e.g., counterfeit or shadow IT).
- SCRM controls in maintenance-related situations including monitoring for unauthorized modifications, communicating changes, and monitoring for EOL.

NIST defines "supply chain" as "a system of organizations, people, activities, information, and resources, possibly international in scope, which provides products or services to consumers."¹⁴⁶ Supply chains evolve continuously through mergers and acquisitions, joint ventures, and other partnership agreements. Supply chains can be dispersed around the world.

Entities interact with a supply chain when they develop, acquire, and maintain logical or physical systems or components (e.g., computers, servers, and other hardware components, software, or services), and when they engage with a third party for a service. Even when an entity develops its own systems and components and manages its own infrastructure, it will still periodically interact with one or more supply chains when purchasing additional external hardware, software, raw materials, and services. As entities increase their reliance on third parties for systems, components, and services, supply chains are more complex, diverse, and interconnected.

If the entity incorporates systems and components from third parties in their development and maintenance activities, consideration of SCRM in the SDLC is appropriate. Awareness of risks arising from integration with suppliers' systems and components helps with management of associated risks such as compatibility issues, backdoors, or unauthorized access points. Whether developed in-house or by a supply chain partner, additional scrutiny should be applied when custom development of systems and components occurs to ensure proper configuration to meet business and information security needs.

Supply chain risk is defined as "the potential for harm or compromise that arises as a result of security risks from suppliers, their supply chains, and their products or services. Supply chain risks include exposures, threats, and vulnerabilities associated with the products and services traversing the supply chain as well as the exposures, threats, and vulnerabilities to the supply chain."¹⁴⁷ Examples of supply chain risks include counterfeit goods (e.g., unauthorized systems or components sold as authentic goods), substandard materials, loss of functionality, theft of data

¹⁴⁶ Refer to NIST SP 800-161r1, [Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations](#).

¹⁴⁷ Refer to [NIST Glossary](#).

or intellectual property (e.g., customer data and logos), and malware inserted into authentic systems and components.

Another supply chain risk is the potential to contract with a third party on the [U.S. Department of the Treasury’s Office of Foreign Assets Control \(OFAC\) Sanctions List](#) or located in countries that are on the list. Management should ensure that the entity’s supply chain partners are not on the OFAC list.¹⁴⁸ This may include evaluating the third party’s ownership structure (including identifying any beneficial ownership whether public or private, foreign or domestic).¹⁴⁹ To accurately determine whether a third party is on the list or affiliated with companies on the list, it is important to consider any nested relationships through common ownership or any subsidiary or affiliate relationships. It is important to understand risks related to supply chains by tracking interdependencies between all parties involved (e.g., owners and third-party service providers, including vendors) in the supply chain.

Supply chain risks increase when supply chain partners are unstable financially or during times of economic, cyber, or logistical disruption to the operations and continuity of key supply chain elements.¹⁵⁰ These partners include third parties and their supply chain partners (also referred to as fourth parties). Some supply chain attackers use indirect paths and trusted relationships to gain access to the entity for disruptive purposes, financial gain, or to obtain intelligence. Attackers often exploit a third-party service provider’s supply chain to access multiple other victim businesses (i.e., the service provider’s customers) for subsequent attacks.

IV.Q.1 Supply Chain Risk Management

SCRM is the systematic process for managing supply chain risk by identifying susceptibilities, vulnerabilities, and threats throughout the supply chain and developing mitigation strategies to combat those threats whether presented by the supplier, the supplier’s product and its subcomponents, or the supply chain (e.g., initial production, packaging, handling, storage, transport, mission operation, and disposal).¹⁵¹ SCRM builds on traditional acquisition and procurement practices by adding processes to identify, measure, monitor, and control risks throughout the supply chain. SCRM processes provide entity management with information to help supplement third-party risk management activities (e.g., due diligence and contract negotiation) and procurement of systems or components by presenting all elements in the supply chain for evaluation.

¹⁴⁸ Per the U.S. Department of the Treasury’s Office of Foreign Assets Control’s (OFAC) “[Basic Information on OFAC and Sanctions](#),” “U.S. persons must comply with OFAC regulations, including all U.S. citizens and permanent resident aliens regardless of where they are located, all persons and entities within the United States, all U.S. incorporated entities and their foreign branches. In the cases of certain programs, foreign subsidiaries owned or controlled by U.S. companies also must comply. Certain programs also require foreign persons in possession of U.S.-origin goods to comply.”

¹⁴⁹ Refer to [Interagency Guidance on Third-Party Relationships: Risk Management](#).

¹⁵⁰ Refer to NIST IR 8419, [Blockchain and Related Technologies to Support Manufacturing Supply Chain Traceability: Needs and Industry Perspectives](#).

¹⁵¹ Refer to [NIST Glossary](#).

Management should monitor, control, and protect communications (i.e., information transmitted or received) applicable to supply chain-related activities at key access points (e.g., external boundaries and key internal boundaries). Effective management uses architectural designs, software development techniques, and systems engineering principles to promote effective information security in the supply chain by identifying and mitigating potential SCRM-related risk.

An attempt should be made to identify potential single points of failure among all entities in the entity's supply chain due to the numerous interconnectivities and risks from all partners. Review of documents, such as system and network topologies and process flow diagrams, may help with identification of these single points of failure.

NIST identifies SCRM high-level controls in various documents.¹⁵² Management should consider the following controls in all development, acquisition, and maintenance activities.

- **SCRM policies, standards, and procedures** that
 - Align with other internal and external policies, standards, and procedures (e.g., information security and business continuity management).
 - Instruct staff on how to choose hardware, software, and third-party service providers from an SCRM perspective.
 - Address system and component supply chain traceability.
 - Specify supply chain due diligence for new vendors, third-party service providers, and ongoing supply chain monitoring. The initial assessment should occur during the initiation phase of a project, before new products or services are provided, or new contracts are signed. Due diligence activities should include at least identification and understanding of the criticality of supported function(s), its critical components, and the sensitivity of the information that may be accessible by the supplied system, component, or third party.
 - Identify security standards (e.g., percentage of open-source components allowed and access requirements) for purchased products and supply chain partners. It is important for management to consider starting with applicable, established national and international standards as a baseline for security requirements for the entity's supply chain.
 - Specify information protection processes including what data may be shared, the sharing method, and to whom information is shared (the specific roles). Processes should account for appropriate privacy protections and any dissemination prohibitions, safekeeping, and clearance (e.g., security and access control) requirements.
 - Detail information retention and disposal requirements, especially when sensitive and proprietary information of a supply chain partner is concerned.
- **SCRM plan** contains steps to assess, monitor, and respond to risks associated with supply chain interaction and procurement activities. The plan describes entity and supply chain implementations, requirements, constraints, and implications at the system level. The SCRM

¹⁵² Refer to NIST SP 800-53, rev. 5, [Security and Privacy Controls for Information Systems and Organizations](#), and NIST SP 800-161r1, [Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations](#).

plan can be stand-alone but is often part of an entity's information security program and third-party risk management program. The plan should address supply chain risks associated with geographic location (e.g., defining acceptable locations). The entity should define roles and responsibilities for personnel (e.g., development, acquisition, and maintenance) to address various risks associated with supply chain activities.

- **General controls and processes** are based on the SCRM plan and entity risk assessments. Management analyzes the risks and designs controls to mitigate risks to an acceptable level as defined by entity senior management and the board. To promote confidentiality, integrity, availability, and resilience throughout the supply chain, controls and processes should include development, information security (e.g., access control and other relevant laws and regulations),¹⁵³ procurement, supplier diversity,¹⁵⁴ and contractual provisions (e.g., clauses stating that contractual requirements apply to any subcontractors). Management should provide the following:
 - Appropriate protections in the information systems, components, and networks for data in transit and at rest for the supply chain partners' information, such as source code testing data, blueprints, and intellectual property.
 - Tamper-resistance and detection controls for critical components.¹⁵⁵
 - Appropriate logging, disparate data correlation, and alerting controls (e.g., access logs, usage pattern reports, and time of day access reports) to obtain evidence in the event of a supply chain compromise.
 - Appropriately segregated and isolated environments between the entity and its supply chain partners to minimize the effect of information leakage across IT environments (e.g., development, testing, and production).
 - Controls over the use of security assessment and monitoring tools within and between IT environments.
 - Logical and physical access controls, such as identification and authentication (e.g., out-of-band validation) for user access to systems and components throughout the supply chain, providing for timely update and periodic review.
 - Current access and authentication lists and appropriate controls to minimize the potential for insider threats as entities develop and acquire systems and components.
 - Formal process for assigning identifiers (e.g., names, numbers, and blockchain) to systems and components (e.g., digital and physical) for management and control throughout the supply chain.
 - Provisions for physical and logical resilience and appropriate implementation of controls in the entity's agreements with supply chain partners.
 - Appropriate monitoring tools and processes at the boundaries between the entity's systems and supply chain partners' systems.

¹⁵³ Refer to FTC 16 CFR 314, "[Standards for Safeguarding Customer Information](#)."

¹⁵⁴ Management should consider supplier diversity for resilience purposes. If only one supplier is relied upon for products or services and is unable to provide them, business could be interrupted; therefore, additional suppliers should be considered. Conversely, too many suppliers may be difficult to manage, and confidentiality, availability, and integrity or quality of service may be compromised.

¹⁵⁵ Criticality analysis can help determine which components are critical.

- **Inventory** is a foundational building block for supply chain management. The entity may rely on third parties to support its strategy and operational functions. Management should develop, document, and maintain an accurate inventory of third parties that reflects the entity's key supply chain partners. Management determines the third party's criticality based on the systems and components the supplier's products and services support and the entity's level of dependency on the supplier for business function. The inventory should be detailed enough for identifying criticality and supply chain risk for tracking and reporting. The inventory should be periodically reviewed and updated, including
 - Description of the supplied products and services (e.g., model or software version).
 - Programs, projects, systems, and components that use the supplier's products and services (i.e., interconnectivities).
 - Assigned criticality level that aligns to the criticality of the program, project, system, component, or service.
- **Configuration management** allows management to track changes made throughout the SDLC to systems, components, and documentation, which is important for tracking details of changes made (e.g., what changes were made, who made them, and who authorized them). Configuration management processes help identify evidence (e.g., baselines and authorizations) used for investigations of potential supply chain cybersecurity compromise. Configuration management is critical to the entity's ability to establish the provenance of components, including tracking and tracing them through the SDLC and the supply chain. It is important to consider configuration management minimum security requirements for the supply chain. Management should apply appropriate configuration management controls to its own systems and encourage or require the use of comparable controls by all parties in the entity's supply chain through contracts. For more information, refer to the *FFIEC IT Handbook's* "[Information Security](#)" booklet.
- **Resilience** should be considered from the beginning of the SDLC and maintained throughout the useful life of the system or component. This aids in cost reduction and efficiency of implementation and includes planning for alternative third-party service providers and vendors of systems, components, and services. Another resilience consideration is alternative delivery routes if the primary one is unavailable, especially when it applies to a critical provider. Management can improve resilience by using platform-agnostic systems and components that allow for portability that will improve resilience throughout the supply chain. Having multiple third-party sources (i.e., heterogeneity)¹⁵⁶ for supply of systems and components can result in alternatives for availability and reduce the potential impact of a supply chain compromise. In those situations, an alternative source of supply allows an entity to more rapidly switch to an alternative system or component that may not be affected. Additionally, having heterogeneous components may help decrease the attack surface and impact of a compromise. This is because all systems and components are not alike; therefore, while they may be exposed to similar risks, they may not be exposed to identical vulnerabilities. Additionally, many risk mitigation solutions used for contingency planning (e.g., alternative storage and processing sites and telecommunication pathways) may have their own supply chains with additional risks. Entity management should understand and mitigate all relevant risks associated with interdependencies throughout the various supply

¹⁵⁶ Heterogeneity techniques include the use of distributed storage and processing, different Oss, virtualization techniques, and multiple sources of supply.

chains potentially affecting the entity. Management should plan for certain scenarios, including

- Unplanned system or component failure and subsequent replacement.
- Planned replacement related to feature improvements, maintenance, upgrades, and modernization.
- Product or service disruption (e.g., loss or degradation of data or operations).

Potential supply chain disruptions affect the entity's operations (e.g., transportation issues, system and component availability problems, or financial difficulties of entities in the supply chain). Management should consider provisions for excess capacity, bandwidth, and redundancy in agreements with supply chain partners and take appropriate mitigation steps, as necessary. For more information, refer to the *FFIEC IT Handbook's* "[Business Continuity Management](#)" booklet.

- **Provenance** involves the chronology of the origin, development, ownership, location, and changes to a system or system component and associated data. Provenance may include personnel and processes used to interact with or make modifications to the system, component, or associated data.¹⁵⁷ Effective management documents provenance for systems, components, and data, and monitors for changes in the chain of custody that may increase risk to the entity throughout the SDLC. Management should consider producing software bills of material (SBOM)¹⁵⁸ for applicable and appropriate classes of software (e.g., purchased, open-source, and in-house developed software). SBOMs should be digitally signed using a verifiable and trusted key, enabling entities to establish provenance. For more information on SBOMs, refer to the "[Software Bill of Material](#)" section of this booklet.
- **Supply chain partner assessments and reviews** should be part of the entity's third-party and supply chain risk management processes, as appropriate. SCRM assessments should include the supply chain infrastructure (e.g., development and testing environments and delivery systems) and the information systems or components traversing the supply chain and should align with enterprise risk management processes and governance. As part of the risk assessment, the entity should have an accurate inventory of suppliers that identifies their criticality to the business. It is important for entity personnel to consider any information pertinent to the security, integrity, resilience, quality, trustworthiness (e.g., not on the OFAC list), or authenticity of their supply chain partners and products. Management should consistently evaluate supply chain partners consistent with the specific context and purpose for which the assessment is being conducted, selecting additional factors for consideration based on supply chain risk. The quality of information (e.g., its relevance, completeness, and accuracy) relied on for an assessment is an important consideration; therefore, management should document the reference sources.

If an entity has a PMO, it can help define requirements, methods, and tools for supply chain partner assessments. Irrespective of the entity's project management methodology, effective project management processes can help identify critical components, especially those that are

¹⁵⁷ Refer to [NIST Glossary](#).

¹⁵⁸ NIST Glossary defines "[SBOM](#)" as a "formal record containing the details and supply chain relationships of various components used in building software. Software developers and vendors often create products by assembling existing open-source and commercial software components. The SBOM [lists] these components [for a given] product."

used by multiple business lines, functions, systems, and components. For example, effective management considers the following practices:

- Determine whether there is potential foreign ownership or influence and whether the supply chain partner may have relationships with OFAC-sanctioned individuals, organizations, or countries.
- Evaluate supply chain partner oversight of its subcontractors (i.e., fourth parties) or developers.
- Identify the level of open-source systems and components used by the entity, and determine how the supply chain partner demonstrates its compliance with applicable open-source licensing agreements.
- Conduct research on COTS systems and components (e.g., via publicly available resources) or request proof to determine whether the supply chain partner (e.g., original equipment manufacturer [OEM]) has performed testing as part of their quality or security processes.
- Use authorized resellers or distributors with an ongoing relationship with the supply chain partner for systems and components not directly acquired from an OEM entity.
- Acquire directly from vetted OEMs or their authorized distributors and resellers when obtaining alternative sources for continued support. Decisions about using alternative sources (i.e., other than OEMs or authorized resellers and servicers) should consider input from all stakeholders (e.g., business lines, IT, CISO, and compliance).
- Track chain of custody of systems, components, and underlying code as they move throughout the supply chain to minimize the potential for counterfeit or altered products. Use of mechanisms, such as radio frequency identification (RFID), digital signatures, bar code scanning, or blockchain to employ supply chain protection techniques in the acquisition, development, and use of code may be deployed throughout the entity to facilitate tracking chain of custody. These techniques include ensuring that¹⁵⁹
 - Code (including mobile code) originates from vetted sources when acquired.
 - Vetted system and component integrators are used for the development of custom code before installing.
 - Verification processes are in place for acceptance criteria before installation to verify the source and integrity of code.
- **Audit and assurance (internal)** to validate management's assessment of risks in the supply chain, including activities to assess an entity's supply chain partners. Internal audit and assurance activities may include the following:
 - Review of system or component documentation.
 - Review of processes for tracking reports to measure adherence to SLAs.
 - Use of service provider system and organization control (SOC) reports and other independent review reports to validate that supply chain partners meet the entity's minimum standards and implement timely corrective actions for identified deficiencies.

¹⁵⁹ Refer to NIST SP 800-161r1, [Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations](#).

- Verification of suppliers' claims of conformance to contractual security and compliance requirements.
- Validation of system or component integrity.
- Use of validation tools and techniques (e.g., scanning) for detecting malware or counterfeit goods (e.g., unauthorized systems or components sold as authentic goods). Additionally, management may use manual inspection techniques for identifying genuine components.
- Verification of ongoing training to ensure that appropriate personnel are aware of emerging supply chain risks.
- **Supply chain operational security** is important because of the interconnectedness of numerous relationships with supply chain partners and the difficulty in coordinating multiple operational security efforts, which creates the opportunity for a potential breach. Effective management communicates with its supply chain partners to promote awareness of threat intelligence and relevant vulnerabilities in the entity's supply chain to inform operational security processes. In some situations, entity management may choose to withhold information from supply chain partners to prevent parties with malicious intent from using the information to compromise the entity. To protect against compromise,
 - Management should consider employing techniques to introduce randomness¹⁶⁰ into entity operations and assets in the entity's systems or networks.
 - Management should consider concealment techniques, such as masking metadata that may be accessible in downloads or deliveries of systems and components, whether developed or acquired.
 - If management considers advanced security protection techniques (e.g., misdirection, honeypots) beyond standard industry techniques (e.g., basic randomness and concealment), it should discuss these techniques with the entity's legal counsel and board, as appropriate, before implementation, as they may present liability and additional risk to the entity.
- **Agreements**¹⁶¹ between the entity and its supply chain partners should include provisions addressing common supply chain risks, including their applicability to any subcontractors. Agreements should address risks, including the following:
 - Personnel¹⁶² security controls (e.g., background checks and screening, termination and transfer procedures, and consequences of insider threats) for individuals with access to the entity's supply chain.

¹⁶⁰ For purposes of this discussion, randomness includes randomly switching among several delivery enterprises or routes or changing the time and date of receiving supplier software updates if previously predictably scheduled. For more information, refer to NIST SP 800-161r1, [Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations](#).

¹⁶¹ Agreements may include contracts, contract addendums, service level agreements (SLA), and operating agreements.

¹⁶² Supply chain-related personnel, whether internal or third-party, may include acquisition and contracting professionals, program managers, supply chain and logistics professionals, shipping and receiving staff, IT professionals, business owners, system owners, and information security engineers.

- Off-boarding procedures to maintain security of entity or supply chain partner information at the close of a contract or end of service to prevent the misuse of sensitive entity or customer information. Agreements should address relationship termination to facilitate a secure off-boarding process (e.g., removing data from cloud environments).
- Most recent set of applicable security and functionality requirements as a baseline, with provisions for future enhancement as risk mitigation needs dictate.
- Processes to monitor and track the vulnerability of the supply chain, based on the criticality or risk profile of the supply chain partner, system, component, or service. A system, component, and service inventory may help management to identify assets that may be subject to known vulnerabilities. This may provide a starting point for determining the level of vulnerability monitoring needed for systems, components, and services throughout the entity's supply chain.
- Information sharing (e.g., collection, analysis, and distribution) of threat intelligence, incidents, and other key risk indicators throughout the supply chain. The intelligence gathered enables management to proactively identify and respond to threats in the entity's supply chain. Therefore, management should consider information-sharing clauses in agreements and contracts.
- Procedures and responsibilities of supply chain partners when actionable (i.e., management needs to take action to mitigate the risk in some way) information is learned, indicating that a supply chain partner or a system, component, or service is a target of a specific threat.
- Provisions for boundary (e.g., network perimeters) protections, which should be incorporated into agreements with supply chain partners, when applicable. This should address initial implementation of boundary control requirements for interconnected networks in the supply chain.
- Inclusion of protections (e.g., encryption) for sensitive information at rest or in transit, applicable throughout the supply chain. This is a consideration for assessing compliance with Gramm–Leach–Bliley Act (GLBA) provisions.
- **Incident response** agreements should include the entity's notification requirements for imminent threats (e.g., system, component, service, or supply chain partner may be the target of an attack), incidents, and compromises that may affect the entity.¹⁶³ It is important for management to consider addressing the following incident response-related information in its agreements with its supply chain partners:
 - Definition and triggers of an incident.

¹⁶³ Refer to [Computer-Security Incident Notification Requirements for Banking Organizations and Their Bank Service Providers](#), referenced in agency guidance FDIC FIL-74-2021, "[Computer-Security Incident Notification Final Rule](#)," and OCC Bulletin 2021-55, "[Computer-Security Incident Notification: Final Rule](#)." Implementation is further discussed in FDIC FIL-12-2022, "[Computer-Security Incident Notification Implementation](#)"; FRB SR Letter 22-4/Consumer Affairs (CA) 22-3, "[Contact Information in Relation to Computer-Security Incident Notification Requirements](#)"; and OCC Bulletin 2022-8, "[Information Technology: OCC Points of Contact for Banks' Computer-Security Incident Notifications](#)."

- Roles and responsibilities, including clear boundaries of responsibility, for incident response processes, including third-party expertise.¹⁶⁴
- Methods and timing of incident communication with regulators and supply chain partners. These should be defined in agreements with supply chain partners to ensure an efficient, coordinated incident response effort (e.g., speed of communication, response, corrective actions, and other related activities).
- Incident response training (e.g., threat briefing or incident response exercises) when appropriate.
- Incident response testing with critical supply chain partners, as appropriate.
- Review of the agreement based on lessons learned after incidents and any new intelligence.
- **Tamper resistance and detection** processes allow entity management to recognize when unauthorized changes to systems and components are made in transit between the supply chain partner and the entity. Entity or supply chain partner personnel should inspect critical systems and components to ensure that tamper-resistant controls are in place and to determine whether there is evidence of tampering. Systems and components should be reviewed for tampering before use and periodically thereafter. Provisions for this type of review should be included in contracts with supply chain partners.
- **System or component authenticity and integrity** is critical for managing cybersecurity risks throughout the supply chain. Without effective SCRM and ITAM processes, it may be possible for entity personnel or third parties to use counterfeit systems and components. This may allow for potential security, functionality, quality, and legal weaknesses (e.g., counterfeit components may void contracts, warranties, or insurance coverage), leading to compromise of confidentiality, integrity, and availability of systems, components, services, and data throughout the supply chain. By deploying effective system and component integrity controls, management can mitigate cybersecurity risks, such as insertion of malicious code and use of counterfeits, throughout the supply chain. Effective controls include anti-counterfeit policies and procedures that protect against introducing counterfeit systems and components into the entity's infrastructure (e.g., ATM processor boards with extra communication chips built into the circuitry, noncertified hardware developers). System and component integrity controls may include the following:
 - System and component integrity policy and procedures, including the use of various integrity verification tools and techniques. These tools and techniques may include the following:
 - Digital signature or checksum verification.
 - Acceptance testing for physical systems and components.
 - Verification testing confined to limited-privilege environments, such as sandboxes.
 - Code execution restrictions in limited-privilege environments before implementation in production.
 - Validation that binary or machine-executable code is obtained directly from the OEM or a verified supplier or distributor.

¹⁶⁴ Roles and responsibilities include identification, determination, escalation, notification, handling, analysis, monitoring and tracking, and provisions for third-party expertise (e.g., forensics).